Capstone Project: Metasploitable 2 Security Assessment

- **Tester: Tarun Choudhary**
- **Role:** Cyber security Intern(VAPT)
- **Target System:** Metasploitable 2 (192.168.159.138)
- **Attacking Machine:** Kali Linux 192.168.159.166
- **Methodology:** PTES (Penetration Testing Execution Standard)

---

2. Executive Summary

This report details a comprehensive security assessment of the **Metasploitable 2** virtual environment. The primary objective was to identify critical security weaknesses and demonstrate real-world attack scenarios that could compromise system integrity. The assessment followed the **Penetration Testing Execution Standard (PTES)**, covering a structured lifecycle from initial reconnaissance to remediation planning.

During the assessment, multiple high-risk vulnerabilities were identified across various layers of the infrastructure:

- **Service Backdoors:** Critical flaws were discovered in services such as **VSFTPD 2.3.4** and **UnrealIRCd**, which are known to contain unauthorized access points.
- **Web Application Flaws:** Testing via **Burp Suite** on the Mutillidae application revealed significant **SQL Injection** and **Cross-Site Scripting (XSS)** vulnerabilities.
- **System Impact:** Successful exploitation enabled **Remote Command Execution (RCE)**, allowing for unauthorized shell access and the potential compromise of sensitive database information.

---

3. Technical Findings & Evidence

Vulnerability	Tool Used	Impact
VSFTPD 2.3.4 Backdoor	Metasploit (exploit/unix/ftp/vsftpd_234_backdoor)	Remote shell access
UnrealIRCd Backdoor	Metasploit (exploit/unix/irc/unreal_ircd_3281_backdoor)	Arbitrary command execution
SQL Injection	Burp Suite (Mutillidae login page)	Authentication bypass
Cross-Site Scripting (XSS)	Web Browser (Manual payload injection)	Malicious script execution

---

4. Remediation Strategy

To secure the environment, the following actions are recommended:

- **Patch Management:** Update outdated services like VSFTPD and UnrealIRCd to secure versions.
- **Input Validation:** Use parameterized queries and sanitize all user-supplied data to prevent SQLi and XSS.
- **Hardening:** Disable unnecessary services (e.g., Telnet) and apply the Principle of Least Privilege.
- **Continuous Monitoring:** Perform regular scans using tools like **OpenVAS** to identify new threats.

Tools and Technologies Used

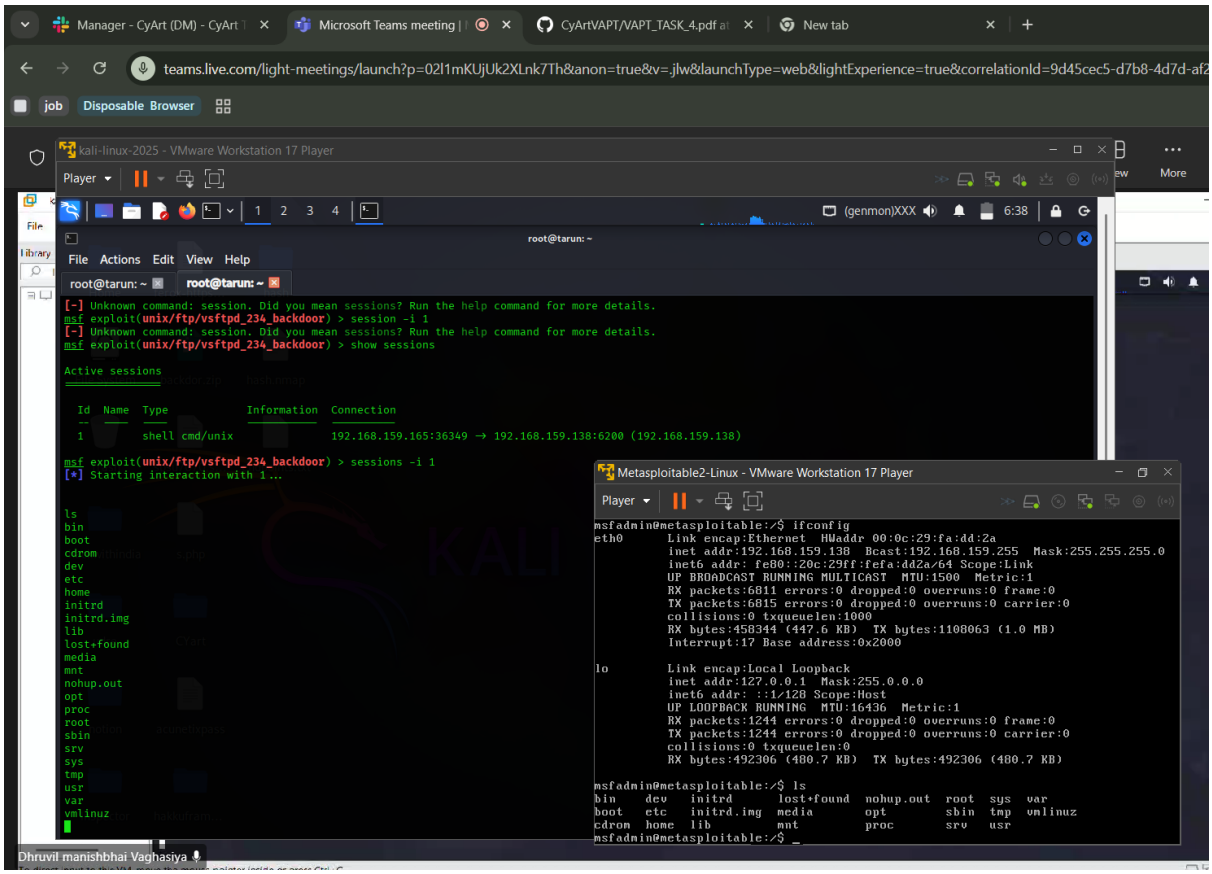
The following tools were utilized during the penetration testing process to identify and exploit vulnerabilities within the target environment:

- **Kali Linux:** Served as the primary penetration testing operating system containing all necessary security tools.
- **Nmap:** Used for initial network scanning and service detection to identify open ports on the target machine.
- **Metasploit Framework:** Employed for the exploitation phase to gain system access through known service vulnerabilities.
- **Burp Suite:** Utilized for web application security testing, specifically for analyzing HTTP requests and testing for SQL Injection and XSS.
- **OpenVAS:** Used for automated vulnerability scanning to detect security weaknesses.

Vulnerability Details

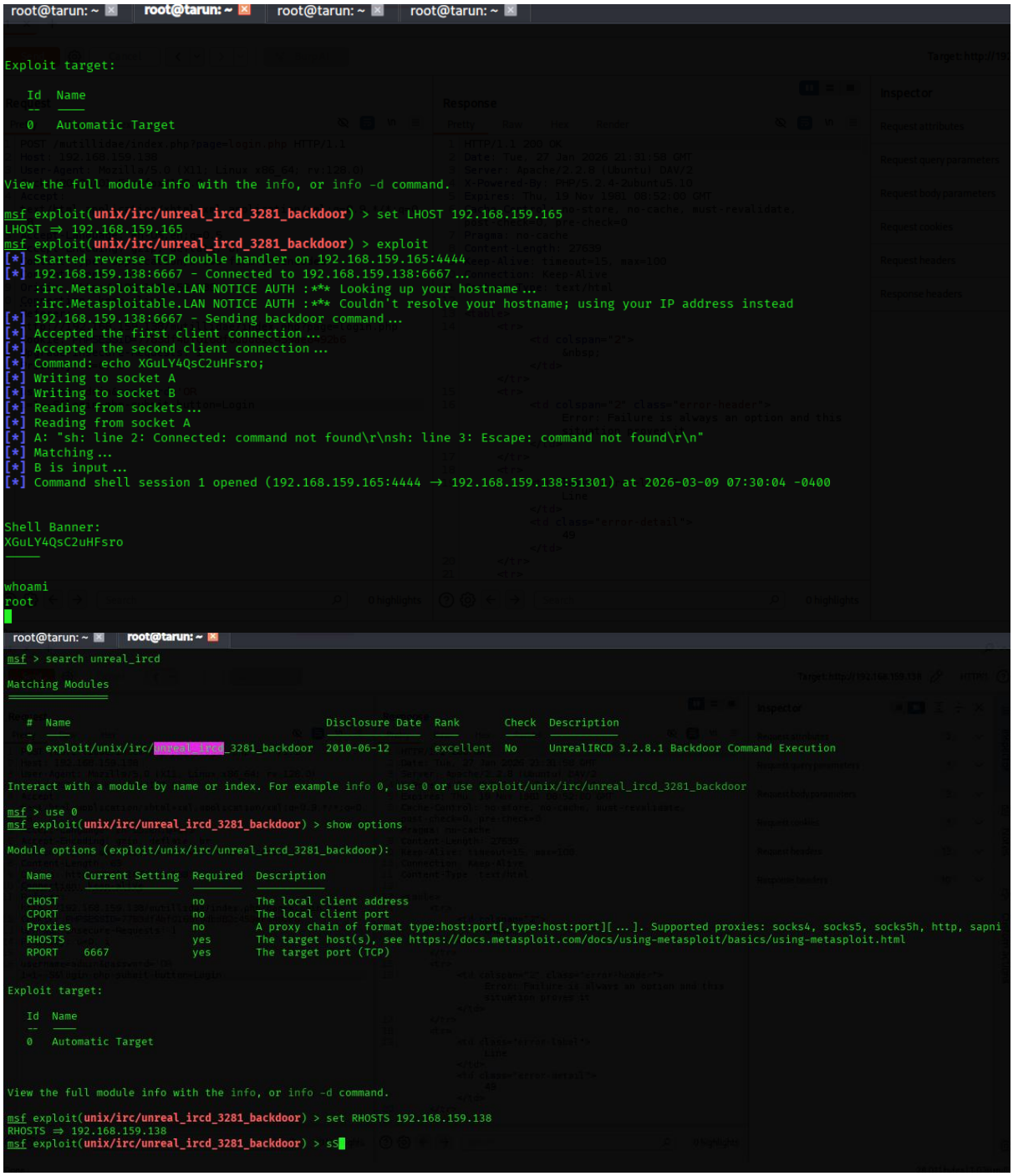
1. VSFTPD 2.3.4 Backdoor

- **Description:** The FTP service running version 2.3.4 contains a known backdoor vulnerability allowing remote command execution.
- **Impact:** An attacker can gain unauthorized shell access.
- **Tool Used:** Metasploit module `exploit/unix/ftp/vsftpd_234_backdoor`.



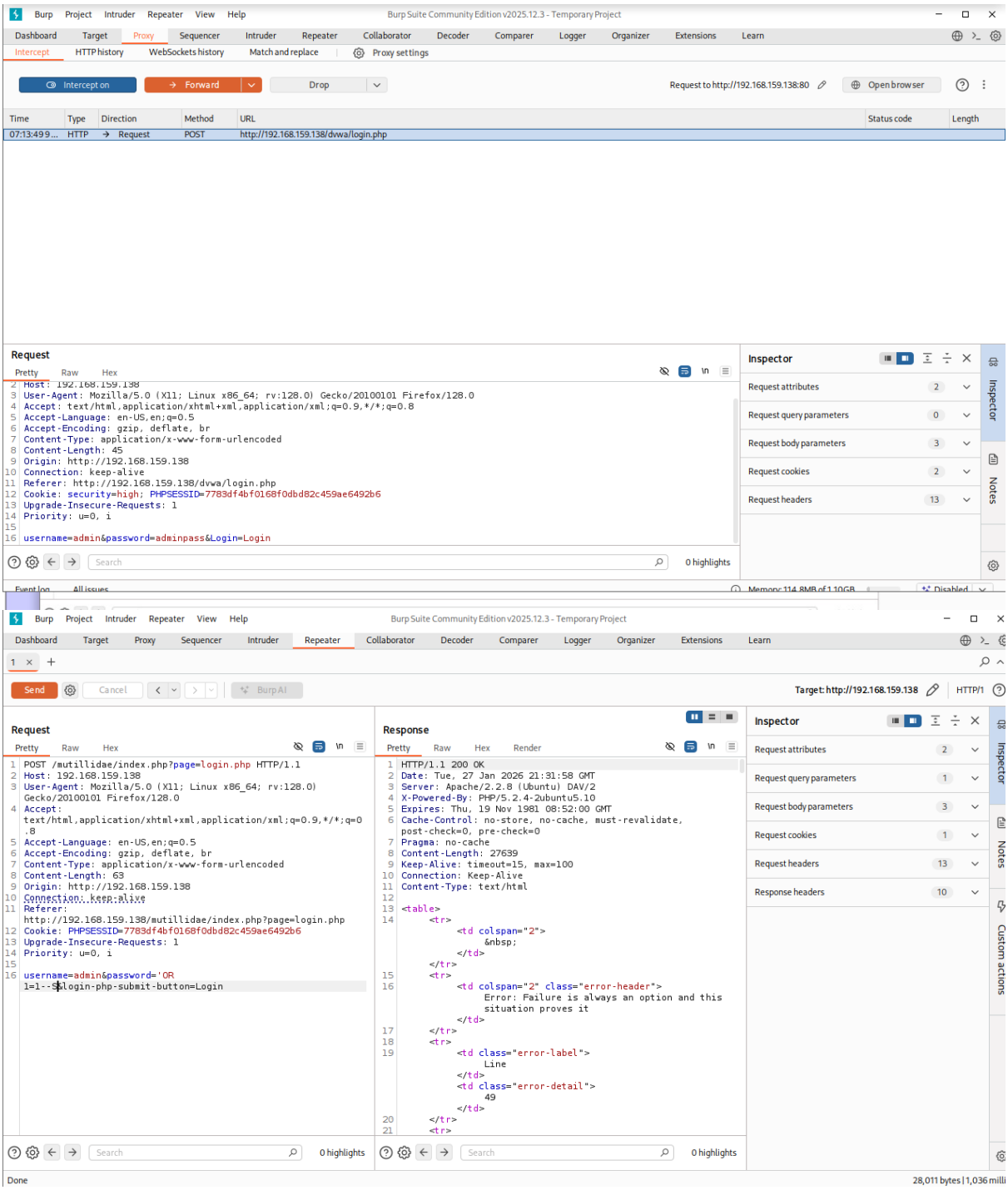
2. UnrealIRCd Backdoor

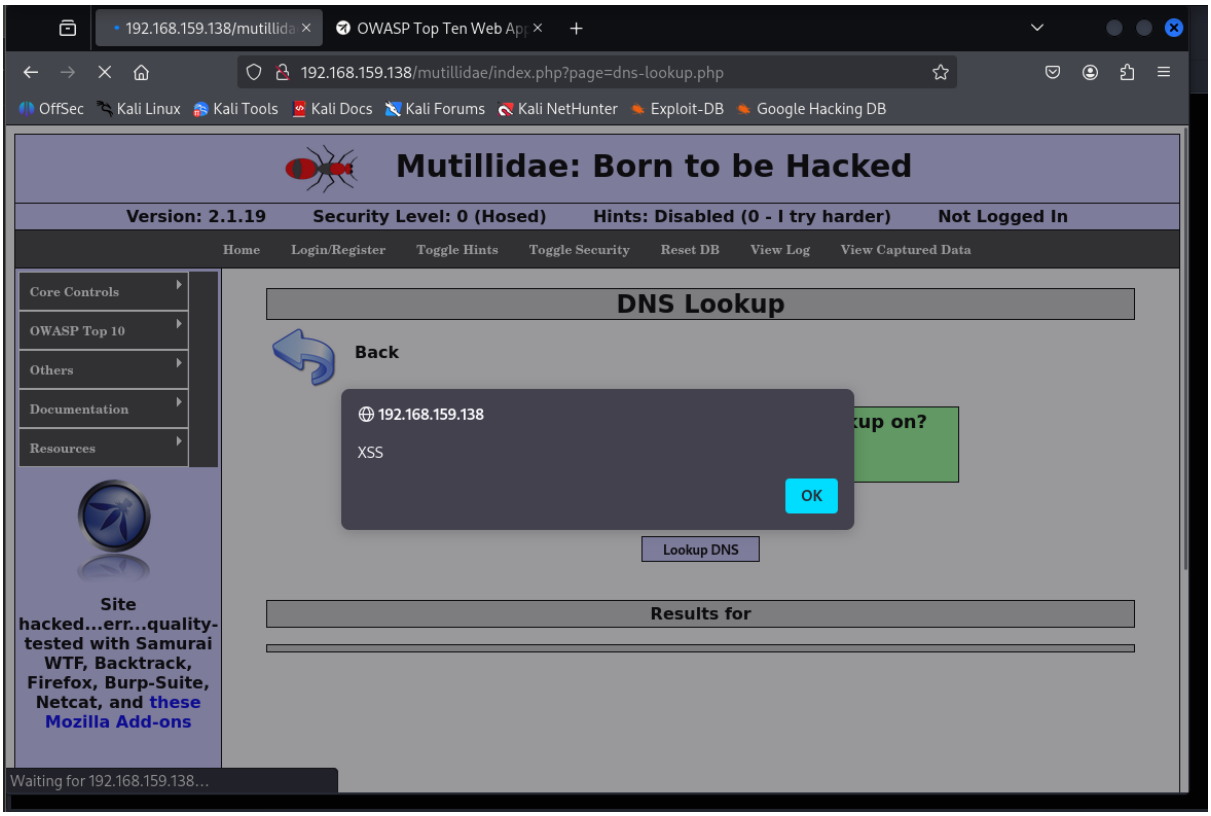
- **Description:** UnrealIRCd version 3.2.8.1 contains a backdoor that allows attackers to execute arbitrary commands remotely.
- **Tool Used:** Metasploit module `exploit/unix/irc/unreal_ircd_3281_backdoor`.



3. SQL Injection

- **Location:** Mutillidae login page.
- **Description:** The login form does not properly validate user input, allowing attackers to manipulate SQL queries.
- **Payload:** `admin' OR ' 1=1`
- **Impact:** Authentication bypass and database compromise.



4. Cross-Site Scripting (XSS)

- **Description:** User input is not properly sanitized.
- **Payload used:** `<script>alert('XSS')</script>`
- **Impact:** Attackers can execute malicious scripts in a user's browser.